

Third-Party Vendor Risk Assessment,

CloudDesk Solutions

Overview

This project demonstrates a practical Third-Party Risk Management (TPRM) assessment for a fictional SaaS vendor being considered by a financial services organization.

The project simulates the work performed by a GRC analyst during vendor due diligence, including security questionnaire review, control assessment, evidence evaluation, risk assessment, gap analysis, remediation planning, and vendor approval.

The vendor used in this project is **CloudDesk Solutions**, a fictional cloud-based customer-support and workflow management provider.

Business Scenario

FinServe Financial Services is considering CloudDesk Solutions as a SaaS provider for customer-support and workflow management.

The proposed service may process:

- Customer-support information
- Customer contact information

- Employee information
- Internal business information
- Operational records

Because CloudDesk would process potentially confidential information and support an important business function, FinServe requires a formal third-party risk assessment before unrestricted production use.

Project Objectives

The objectives of this assessment were to:

1. Profile the proposed vendor.
2. Conduct vendor security due diligence.
3. Evaluate vendor security controls.
4. Review supporting evidence.
5. Identify control gaps.
6. Assess vendor risks.
7. Develop a remediation plan.
8. Determine an overall vendor risk rating.
9. Produce an executive-level vendor risk report.
10. Provide a documented vendor approval recommendation.

Project Structure

Project-3-Third-Party-Vendor-Risk-Assessment/

|

|— README.md

|

|— 00-Vendor-Profile/

| |— CloudDesk-Vendor-Profile.docx

|

|— 01-Vendor-Questionnaire/

| |— CloudDesk-Security-Questionnaire.xlsx

|

|— 02-Vendor-Risk-Assessment/

| |— CloudDesk-Vendor-Risk-Assessment.xlsx

|

|— 03-Security-Control-Assessment/

| |— CloudDesk-Control-Assessment.xlsx

|

|— 04-Evidence-Review/

| |— CloudDesk-Evidence-Review.xlsx

|

|— 05-Gap-Analysis/

| |— CloudDesk-Gap-Analysis.xlsx

|

|— 06-Risk-Register/

- | └── CloudDesk-Risk-Register.xlsx
- |
- |── 07-Remediation-Plan/
- | └── CloudDesk-Remediation-Plan.xlsx
- |
- |── 08-Vendor-Risk-Report/
- | └── CloudDesk-Vendor-Risk-Report.docx
- |
- └── 09-Vendor-Approval-Decision/
- └── CloudDesk-Vendor-Approval-Decision.docx

Assessment Workflow

Vendor Profile



Security Questionnaire



Control Assessment



Evidence Review



Gap Analysis



Risk Register



Remediation Plan



Vendor Risk Report



Approval Decision

Key Findings

The assessment identified eight primary vendor risks involving:

- Data retention
- Access reviews
- Vulnerability assurance
- Penetration testing
- Disaster recovery
- Subprocessor management
- Security monitoring
- Independent security assurance

The overall vendor risk rating was:

HIGH

Vendor Decision

The recommended vendor status is:

CONDITIONAL APPROVAL PENDING REMEDIATION

CloudDesk may continue through the onboarding process subject to remediation, evidence collection, contractual requirements, and appropriate risk oversight.

Unrestricted production deployment should not occur until required high-priority findings have been addressed or formally accepted.

Risk Methodology

Risks were evaluated using:

Risk Score = Likelihood × Impact

Likelihood:

- 1 = Low
- 2 = Medium
- 3 = High

Impact:

- 1 = Low
- 2 = Medium
- 3 = High

The project uses a risk-based approach to prioritize vendor findings and remediation activities.

GRC Skills Demonstrated

This project demonstrates practical experience in:

- Third-Party Risk Management
- Vendor Due Diligence
- Security Questionnaires
- Vendor Risk Assessment
- Control Assessment
- Evidence Review
- Gap Analysis
- Risk Registers
- Risk Scoring
- Remediation Planning
- Risk Treatment
- Vendor Approval
- Security Governance
- Data Protection

- Access Control
- Incident Response
- Business Continuity
- Vendor Monitoring
- Executive Reporting

Key GRC Concepts Demonstrated

Due Diligence

Reviewing a vendor's security practices before onboarding.

Evidence-Based Assessment

Evaluating documentation and evidence rather than relying only on vendor statements.

Risk-Based Decision Making

Using identified risks and control weaknesses to determine the appropriate vendor status.

Remediation

Requiring the vendor to address identified control gaps.

Residual Risk

Recognizing that some third-party risk remains even after controls are implemented.

Continuous Monitoring

Recognizing that vendor risk management is an ongoing process rather than a one-time assessment.

Final Assessment

Vendor: CloudDesk Solutions

Vendor Type: SaaS

Business Criticality: High

Data Classification: Confidential

Overall Risk: High

Decision: Conditional Approval

Primary Treatment: Risk Mitigation

Assessment Status: Complete

Author

GRC / Cybersecurity Portfolio Project

Demonstrating practical Third-Party Risk Management and Vendor Security Assessment capabilities.